

GUÍA METODOLÓGICA INTEGRAL — ENCUESTA CRM

Implementación Paso-a-Paso del Kit de Evaluación

Versión: 2.0 | **Fecha:** Enero 2026 | **Clasificación:** Público

I. INTRODUCCIÓN METODOLÓGICA

Esta guía proporciona instrucciones detalladas para ejecutar, analizar e interpretar la Encuesta Integral CRM 2024-2025.

Propósito: Transformar respuestas cuantitativas en score de madurez (IGM), identificar gaps, y generar roadmap priorizado.

Resultado Final: Reporte Ejecutivo + Matriz Gaps + Plan Acción 12-24 meses

II. FASES DE IMPLEMENTACIÓN

FASE 1: PLANIFICACIÓN & PREPARACIÓN (Semana 1)

Paso 1.1 — Definir Alcance

- ¿Encuesta abarca toda la organización o áreas específicas? (ej: solo IT, o global)
- ¿Incluye evaluación terceros/proveedores críticos?
- Timeline: ¿Baseline actual o comparación histórica?

Paso 1.2 — Identificar Stakeholders

- CISO (respondedor principal)
- IT Manager
- Risk Officer
- CTO/Arquitecto
- Compliance Officer
- Business Unit Heads (1-2 representantes)
- Junta Directiva (1 miembro)

Paso 1.3 — Preparar Sesiones

- 2-3 sesiones de 2 horas cada una (vs 1 sesión de 6 horas → fatiga)
- Sesión 1: Gobernanza, Threat Modeling, Supply Chain
- Sesión 2: Cuantificación, Compliance, Automatización
- Sesión 3: Métricas SOC, Vulnerabilidades, Awareness
- Sesión 4 (opcional): Validación respuestas + consenso

FASE 2: EJECUCIÓN ENCUESTA (Semanas 2-3)

Paso 2.1 — Distribución Pre-Encuesta

- Enviar encuesta 1 semana antes sesiones presenciales

- Objetivo: Que respondentes reflexionen; acelera discusión
- Formato: Google Form, Qualtrics, o Excel descargable

Paso 2.2 — Facilitation en Sesiones

- No: Ejecutar encuesta pasivamente
- Sí: Usar encuesta como "conversation starter"
- Facilitador debe:
 - * Hacer preguntas seguimiento ("¿por qué esa respuesta?")
 - * Documentar evidencia (documentos, screenshots)
 - * Buscar consensus si hay desacuerdo

Paso 2.3 — Recopilación Evidencia

- No confiar solo en respuestas; pedir evidencia:
 - * "Dice CISO que existe RAS → pedir documento"
 - * "Dice MTDD <30 min → pedir últimas 10 alertas + timestamps"
 - * "Dice compliance NIS2 → pedir gap analysis"
- Validar; no aceptar claims sin evidencia

Paso 2.4 — Scoring Preliminar

- Tras cada sesión, asignar score 0-4 a cada preuesta:
 - * 0 = No implementado / No aplica
 - * 1 = Ad-hoc / Muy débil
 - * 2 = Implementado pero incompleto
 - * 3 = Implementado; conforme frameworks
 - * 4 = Optimizado; excellence
- No calcular agregado aún; esperar sesiones finales

FASE 3: ANÁLISIS & SCORING (Semana 4)

Paso 3.1 — Scoring por Dominio

Dominio = Cluster de preguntas relacionadas

Ejemplo Scoring Gobernanza:

Q1.1.1 (RAS documentado): Respuesta A = 4 puntos
Q1.1.2 (Risk Tolerance): Respuesta A = 4 puntos
Q1.1.3 (Junta oversight): Respuesta A = 4 puntos
Q1.2.1 (NIST CSF Govern): Respuesta A = 4 puntos
Q1.2.2 (CISO designado): Respuesta A = 4 puntos

Dominio Gobernanza Score = $(4+4+4+4+4) / 5 = 4.0$

Paso 3.2 — Cálculo IGM (Índice Global Madurez)

IGM = Promedio de todos dominios

Ejemplo:

Gobernanza: 3.5
Cuantificación FAIR: 2.0
Threat Modeling: 2.5
SOC/SIEM: 3.0
Vulnerabilidades: 3.2
Supply Chain: 1.5
Awareness: 2.8
Compliance: 2.2
Automatización: 1.8

$$\text{IGM} = (3.5 + 2.0 + 2.5 + 3.0 + 3.2 + 1.5 + 2.8 + 2.2 + 1.8) / 9 = 2.42 \text{ (Formativo)}$$

Paso 3.3 — Clasificación Madurez

IGM Score	Nivel	Descripción
0.0 - 1.5	1 — Startup	Ad-hoc, informal, no institucionalizado
1.5 - 2.5	2 — Formativo	Algunos procesos, parcialmente institucionalizado
2.5 - 3.5	3 — Establecido	Estándarizado, institucionalizado
3.5 - 4.5	4 — Estratégico	Medido, optimizado, mejora continua
4.5 - 5.0	5 — Dinámico	Innovación continua, anticipatorio

España 2024 baseline: IGM ~2.4 (Formativo)

FASE 4: ANÁLISIS GAPS (Semana 5)

Paso 4.1 — Identificar Gaps

Gap = Diferencia entre estado actual vs target

Ejemplo:

Gobernanza (actual 3.5 → target 4.5): GAP = -1.0
Cuantificación (actual 2.0 → target 4.0): GAP = -2.0 (CRÍTICO)
Threat Modeling (actual 2.5 → target 3.5): GAP = -1.0
...

Paso 4.2 — Priorización Gaps

Matriz Impacto × Esfuerzo:

ALTO IMPACTO	BAJO ESFUERZO ★ QUICK WINS (Hazlo primero)	ALTO ESFUERZO 🎯 STRATEGIC (Roadmap 12m)
BAJO IMPACTO	📋 NICE-TO-HAVE (Backlog)	❌ AVOID (No hacer)

Paso 4.3 — Validar Gaps

Preguntar:

- ¿Por qué existe este gap?
- ¿Qué recursos (\$ €, personas, tiempo) necesarios?
- ¿Timeline realista?

FASE 5: GENERACIÓN ROADMAP (Semana 6)

Paso 5.1 — Definir Objetivos 12-24 meses

Ej:

- Q2 2026: IGM 2.4 → 2.8 (Formativo → lower Establecido)
- Q4 2026: IGM 2.8 → 3.2
- Q4 2027: IGM 3.2 → 3.8 (Estratégico)

Paso 5.2 — Definir Iniciativas Prioritarias

Top 5-7 iniciativas basadas gaps CRÍTICOS:

Ejemplo roadmap 12 meses:

Q2 2026:

1. Implementar FAIR framework (2 semanas, \$50K)
2. Documentar RAS + Risk Tolerance (3 semanas, \$10K)
3. CISO designado formalmente (1 semana, org change)

Q3 2026:

4. SIEM + SOAR implementation (8 semanas, \$300K)
5. PASTA threat modeling top 10 apps (12 semanas, \$80K)

Q4 2026:

6. NIS2 compliance assessment (4 semanas, \$60K)
7. Phishing simulation program (6 semanas, \$30K)

PRESUPUESTO TOTAL: ~\$530K + 52 semanas consulting

III. CÁLCULO MÉTRICAS DERIVADAS

Métricas por Dominio

1. GOVERNANCE MATURITY
= (RAS + Risk Tolerance + Junta Oversight + NIST CSF + CIS0) / 5
2. QUANTIFICATION MATURITY
= (FAIR Adoption + ALE Knowledge + ROI Analysis) / 3
3. THREAT MODELING MATURITY
= (Threat Modeling Method + Attack Trees + Threat-Vuln Mapping) / 3
4. SOC/SIEM MATURITY
= (SOC Existence + MTTD/MTTR + SIEM Capability + Automation) / 4
5. VULNERABILITY MATURITY
= (Scanning Frequency + Patch SLA + CVSS Usage + SLA Compliance) / 4
6. SUPPLY CHAIN MATURITY
= (Vendor Audit + Contractual Requirements + SBOM) / 3
7. AWARENESS MATURITY
= (Training Mandatory + Phishing Sims + Click Rate + ROI Calc) / 4
8. COMPLIANCE MATURITY
= (NIST CSF Eval + NIS2 Readiness + DORA Compliance) / 3
9. AUTOMATION MATURITY
= (Policy-as-Code + Infrastructure-as-Code + Resilience Testing) / 3

IGM FINAL = Promedio todos 9 dominios

IV. COMPARATIVAS & BENCHMARKING

Benchmark España 2024-2025

Dominio	España Median	Leader EU	Brecha
Gobernanza	2.8	4.2	-1.4
Cuantificación	1.8	3.8	-2.0
Threat Modeling	2.2	3.5	-1.3
SOC/SIEM	2.6	4.0	-1.4
Vulnerabilidades	3.0	4.1	-1.1
Supply Chain	1.9	3.6	-1.7
Awareness	2.4	3.8	-1.4
Compliance	2.3	4.0	-1.7
Automatización	1.5	3.7	-2.2
IGM Agregado	2.38	3.86	-1.48

Interpretación: España típicamente 1.5 niveles por debajo líderes UE.

V. SESIONES DE SEGUIMIENTO

Post-Encuesta (Mes 2-4)

Sesión Validación (Semana 8):

- Presentar scoring preliminar
- Revisar evidencia dudosa
- Consenso sobre gaps

Sesión Gaps (Semana 10):

- Presentar matriz gaps prioritizados
- Discutir recursos requeridos
- Validar roadmap

Sesión Roadmap (Semana 12):

- Aprobación Junta iniciativas prioritarias
- Asignación presupuesto
- Designación owners por iniciativa

VI. DOCUMENTACIÓN SALIDAS

Cada fase genera documento:

Fase	Documento	Audiencia
Análisis	Scoring Detallado (1-page)	CISO + Risk Officer
Gaps	Matriz Gaps Priorizada (1-page)	CISO + CFO
Roadmap	Roadmap 12-24m (2-pages)	Junta Directiva
Ejecutivo	Reporte Ejecutivo (5-10 pages)	CEO + Board

VII. PREGUNTAS FRECUENTES

P: ¿Cuánto tiempo lleva la encuesta completa?

A: 4-6 semanas incluyendo todas fases (encuesta misma = 2-3 horas)

P: ¿Quién debe responder?

A: CISO (lead), IT Manager, Risk Officer, CTO. Consenso recomendado.

P: ¿Frecuencia de re-evaluation?

A: Anual recomendado (cambios amenaza, regulación, inversiones)

P: ¿Cómo usar para presupuesto?

A: Gaps → Iniciativas → Estimados \$ → Business Case para junta

P: ¿Secreto profesional vs transparencia?

A: Ser honesto. Gaps = oportunidad, no "fracaso". Tone constructivo.

Fin Guía Metodológica